

Laboratorio 2

Sesión #2 Diferenciar entre Confidencialidad, Integridad y Disponibilidad

Título del Laboratorio: Diferenciar entre Confidencialidad, Integridad y Disponibilidad

Duración: 2 horas

Objetivos del Laboratorio:

1. Comprender y definir los principios fundamentales de la ciberseguridad (Confidencialidad, Integridad y Disponibilidad)
2. Aplicar los conceptos de Confidencialidad, Integridad y Disponibilidad a escenarios prácticos
3. Analizar y diferenciar los impactos de las brechas en Confidencialidad, Integridad y Disponibilidad

Materiales Necesarios:

1. Utilizar GitHub como repositorio
2. Utilizar Academia Cisco
3. Computador
4. Acceso a internet

Estructura del Laboratorio:

1. Paso 1: Definir los Términos Clave (Confidencialidad, Integridad y Disponibilidad)

Confidencialidad:

- **Definición:** Explica que la confidencialidad se refiere a la protección de la información para asegurar que solo las personas autorizadas puedan acceder a ella. Es uno de los pilares fundamentales de la seguridad de la información.
- **Conceptos Relacionados:** Incluye el cifrado, controles de acceso, y autenticación como métodos para garantizar la confidencialidad

Integridad:

- **Definición:** Define la integridad como la protección contra la modificación no autorizada de datos. La integridad asegura que la información es confiable y que no ha sido alterada o manipulada.
- **Conceptos Relacionados:** Menciona el uso de sumas de verificación (hashes), firmas digitales y controles de versiones como métodos para asegurar la integridad.

Disponibilidad:

- **Definición:** Explica que la disponibilidad garantiza que la información y los recursos estén accesibles a los usuarios autorizados cuando lo necesiten. Esto implica que los sistemas sean robustos y que estén disponibles incluso ante fallos o ataques.
- **Conceptos Relacionados:** Discute la redundancia, los sistemas de respaldo, y la planificación ante desastres como formas de garantizar la disponibilidad.

Resultado Esperado:

- Al final de este paso, los participantes deben tener una comprensión clara de los términos y estar preparados para aplicar estos conceptos en ejemplos prácticos.

2. Paso 2: Proporcionar y Analizar Ejemplos Prácticos**Ejemplo de Confidencialidad:**

- **Contexto:** Explicar cómo una empresa de salud maneja los registros médicos de los pacientes.
- **Aplicación Práctica:** Describa cómo se utiliza el cifrado para proteger la información sensible, asegurando que solo el personal médico autorizado pueda acceder a estos datos.
- **Discusión:** Pregunta a los participantes qué otros métodos podrían usarse para garantizar la confidencialidad de los datos en este contexto (por ejemplo, autenticación multifactorial).

Ejemplo de Integridad:

- **Contexto:** Explica cómo una empresa de software distribuye sus productos a los clientes.
- **Aplicación Práctica:** Detalla cómo se utilizan sumas de verificación (hashes) para verificar que los archivos de instalación no han sido alterados durante la descarga.
- **Discusión:** Solicita a los participantes que piensen en qué podría suceder si la integridad no estuviera asegurada (por ejemplo, software malicioso podría ser introducido sin que el usuario lo sepa).

Ejemplo de Disponibilidad:

- **Contexto:** Describe cómo un banco gestiona sus servicios en línea.
- **Aplicación Práctica:** Explica cómo el banco implementa servidores redundantes y sistemas de respaldo para asegurar que sus servicios en línea estén disponibles incluso durante fallos de hardware.
- **Discusión:** Pide a los participantes que discutan las implicaciones de la falta de disponibilidad para un banco, y cómo podría afectar a los clientes y la reputación de la entidad.

Resultado Esperado:

- Los participantes deben ser capaces de asociar cada concepto (Confidencialidad, Integridad, Disponibilidad) con un ejemplo práctico, entendiendo cómo se aplican en diferentes contextos.

3. Paso 3: Reflexión y Comparación de Conceptos**Análisis Comparativo:**

- **Actividad:** Pide a los participantes que comparen los tres conceptos, reflexionando sobre cómo se complementan entre sí en un sistema de seguridad completo. Por ejemplo, cómo un fallo en la confidencialidad podría comprometer la integridad, o

cómo la falta de disponibilidad puede afectar la integridad de los datos.

Preguntas de Reflexión:

- ¿Qué concepto consideras más crítico en el contexto de una empresa de salud? ¿Y en una empresa de comercio electrónico?
- ¿Cómo podrías priorizar la implementación de estos conceptos en una organización con recursos limitados?

Conclusión del Laboratorio:

- Resume cómo la confidencialidad, integridad y disponibilidad trabajan juntas para proteger la información y los sistemas.
- Destaca la importancia de implementar medidas que aseguren los tres aspectos para una ciberseguridad efectiva.

Resultado Esperado:

- Al final de este paso, los participantes deben tener una comprensión integrada de cómo la confidencialidad, integridad y disponibilidad son esenciales para proteger los datos y garantizar la seguridad de la información.

Lista de Verificación Ejemplo:

- Revisar en la academia cisco los conceptos.
- Subir un documento pdf al apartado de tareas con las actividades realizadas.

Solución del laboratorio

Paso 1: Definir los Términos Clave (Confidencialidad, Integridad y Disponibilidad)

Resultado Esperado:

- Al final de este paso, los participantes deben tener una comprensión clara de los términos y estar preparados para aplicar estos conceptos en ejemplos prácticos.

Confidencialidad

Definición:

La confidencialidad se refiere a la protección de la información para asegurar que solo las personas autorizadas puedan acceder a ella. Es uno de los pilares fundamentales de la seguridad de la información.

Conceptos Relacionados:

Cifrado: Es un proceso de codificar la información de manera que solo pueda ser descifrada por quien tenga la clave o llave correspondiente.

Controles de acceso: Los usamos como mecanismos que restringen el acceso a la información basándose en la identidad del usuario y sus permisos.

Autenticación: La implementamos para verificar la identidad de un usuario antes de concederle acceso a determinados recursos o información.

Integridad

Definición:

La integridad consiste en la protección contra la modificación no autorizada de datos. Garantiza que la información es confiable y que no ha sido alterada, manipulada o corrupta desde su creación.

Conceptos Relacionados:

Sumas de verificación (hashes): Valores generados a partir de datos que permiten verificar si estos han sido modificados.

Firmas digitales: Mecanismos criptográficos que proporcionan autenticidad e integridad a los mensajes digitales.

Control de versiones: Sistemas que registran cambios en los documentos o archivos a lo largo del tiempo.

Registros de auditoría: Registros que documentan quién ha accedido a los datos y qué modificaciones se han realizado.

Disponibilidad

Definición:

La disponibilidad garantiza que la información y los recursos estén accesibles a los usuarios autorizados cuando lo necesiten.

Conceptos Relacionados:

Redundancia: Se duplicación de componentes críticos del sistema para evitar puntos únicos de fallo.

Sistemas de respaldo: Se realizan copias de seguridad de datos e infraestructura que pueden activarse en caso de fallos.

Planificación ante desastres: Utilizamos estrategias para mantener o recuperar rápidamente las operaciones tras eventos catastróficos.

Balanceo de carga: Es la distribución del tráfico entre varios servidores para evitar sobrecargas.

Paso 2: Proporcionar y Analizar Ejemplos Prácticos

Resultado Esperado:

- Los participantes deben ser capaces de asociar cada concepto (Confidencialidad, Integridad, Disponibilidad) con un ejemplo práctico, entendiendo cómo se aplican en diferentes contextos.

2.1. Ejemplo de Confidencialidad:

Una empresa de salud maneja los registros médicos de los pacientes.

• Aplicación Práctica:

La empresa utiliza cifrado para proteger los registros de los pacientes.

Solo el personal médico autorizado puede acceder a los datos utilizando autenticación multifactor o biometría.

Se aplican roles y permisos definidos por perfil de usuario.

Sistemas de registro de accesos (logs) para auditar quién accedió a qué información y cuándo.

Todos los empleados deben firmar acuerdos de confidencialidad.

Se establecen protocolos claros para el manejo, almacenamiento, impresión o eliminación de historias clínicas.

Cuando los datos se usan para estudios o reportes estadísticos, se eliminan o codifican los datos personales identificables.

- **Discusión:** Pregunta a los participantes qué otros métodos de seguridad podrían mejorar la confidencialidad en este contexto (ej., monitoreo de accesos).

2.2. Ejemplo de Integridad: Una empresa de software distribuye actualizaciones de productos a sus clientes.

• Aplicación Práctica:

La empresa utiliza hashes para asegurar que los archivos no han sido modificados durante la descarga. Si un cliente descarga una actualización, la suma de verificación del archivo se compara con la suma original.

La empresa firma digitalmente las actualizaciones usando una clave privada. El cliente puede verificar la firma usando la clave pública de la empresa. Esto asegura integridad y autenticidad (que realmente proviene del proveedor oficial).

Uso de canales seguros como HTTPS o SFTP para evitar la manipulación en tránsito.

Algunos sistemas usan redes de distribución de contenido (CDN) confiables y autenticadas.

Sistemas automáticos validan la integridad antes de instalar una actualización.

Se usan checksums en el código para asegurar que los componentes no hayan sido alterados.

Se integran herramientas de DevSecOps en el ciclo de distribución.

En caso de errores de descarga o corrupción, se usan mecanismos de recuperación automática o verificación por repetición de descarga.

Se recomienda mantener versiones anteriores como respaldo.

- **Discusión:** ¿Qué ocurriría si la integridad no se mantuviera? (ej., la instalación de software malicioso sin que los usuarios lo detecten).

2.3. Ejemplo de Disponibilidad: Un banco gestiona sus servicios en línea, como banca digital.

- **Aplicación Práctica:** El banco implementa servidores redundantes y sistemas de respaldo para asegurar que los clientes puedan acceder a los servicios incluso durante una interrupción o fallo del hardware.

1. Alta disponibilidad (High Availability – HA)

Uso de clústeres redundantes de servidores: Si un servidor falla, otro asume automáticamente la carga.

Balanceadores de carga que distribuyen las solicitudes entre varios servidores activos para evitar sobrecargas.

2. Infraestructura redundante

Componentes duplicados: servidores, fuentes de energía, sistemas de red, bases de datos.

Centros de datos en configuración activa-activa o activa-pasiva, en distintas ubicaciones físicas.

3. Computación en la nube y servicios híbridos

Algunos bancos usan soluciones en la nube (como AWS, Azure o Google Cloud) con alta tolerancia a fallos y escalabilidad automática.

Integración de modelos híbridos: una parte en la nube y otra en centros de datos propios (on-premise), para mayor control y redundancia.

4. Replicación de datos en tiempo real

Uso de bases de datos replicadas (ej., PostgreSQL con streaming replication, Oracle Data Guard).

Los datos se sincronizan en tiempo real o casi en tiempo real en múltiples ubicaciones.

5. Planes de continuidad del negocio (BCP) y recuperación ante desastres (DRP)

Bancos tienen protocolos establecidos para restaurar operaciones rápidamente en caso de desastre.

Se realizan pruebas periódicas de recuperación simulada.

6. Actualizaciones con tolerancia a fallos (rolling updates)

Los sistemas se actualizan por partes (nodos, servicios) sin afectar al usuario final.

Se emplea arquitectura de microservicios con contenedores (ej., Docker, Kubernetes) para aislar fallos.

7. Monitoreo 24/7 y respuesta automatizada

Monitoreo continuo de infraestructura, rendimiento y disponibilidad.

Sistemas automáticos de respuesta ante fallos (self-healing systems), que reinician servicios o redirigen tráfico.

8. Sistemas de energía ininterrumpida (UPS) y plantas eléctricas

Protegen contra cortes de energía, garantizando continuidad operativa.

Ejemplo práctico:

Un banco tiene un sistema de banca en línea que corre en dos centros de datos (uno en Bogotá y otro en Medellín). Si el centro en Bogotá falla por corte eléctrico, el tráfico se redirige automáticamente a Medellín, gracias a:

DNS dinámico,

Replicación activa-activa de bases de datos,

Monitoreo y conmutación por error automática (failover).

Paso 3: Reflexión y Comparación de Conceptos

Análisis Comparativo:

Actividad: Pide a los participantes que comparen los tres conceptos y cómo se complementan entre sí en un sistema de seguridad completo. Por ejemplo:

Preguntas de Reflexión:

- **Pregunta 1:** ¿Qué concepto consideras más crítico en una empresa de salud? ¿Y en una empresa de comercio electrónico?
- **Pregunta 2:** ¿Cómo podrías priorizar la implementación de estos conceptos en una organización con recursos limitados?

Acciones concretas con bajo costo

Confidencialidad:

Control de accesos (RBAC).

Uso de cifrado básico (datos sensibles en disco y transmisión).

Políticas de contraseñas y concienciación.

Integridad:

Backups frecuentes y verificados.

Hashes/verificación de archivos críticos.

Registros de auditoría (logs).

Disponibilidad:

Monitoreo básico de servicios (como UptimeRobot).

Backups redundantes (en nube o local).

UPS o alimentación protegida para servidores críticos.